



PDF Download
3736130.3762689.pdf
05 February 2026
Total Citations: 1
Total Downloads: 263

 Latest updates: <https://dl.acm.org/doi/10.1145/3736130.3762689>

RESEARCH-ARTICLE

Structured Threat Modeling Approach for Generating Executable Attack Scenarios in the EV Charging Infrastructure

JAE-JUN HA, Chonnam National University, Gwangju, South Korea

DONG-HYUK SHIN, Chonnam National University, Gwangju, South Korea

CHAE MIN LIM, Chonnam National University, Gwangju, South Korea

IECK CHAE EUOM, Chonnam National University, Gwangju, South Korea

Open Access Support provided by:

Chonnam National University

Published: 13 October 2025

[Citation in BibTeX format](#)

CSCS '25: Proceedings of the 2025 Cyber Security in CarS Workshop
October 13 - 17, 2025
Taipei, Taiwan

Conference Sponsors:
SIGSAC

Structured Threat Modeling Approach for Generating Executable Attack Scenarios in the EV Charging Infrastructure

Jae-Jun Ha*

System Security Research Center, Chonnam National
University
Gwangju, Republic of Korea
wowns1106@jnu.ac.kr

Chae-Min Lim

System Security Research Center, Chonnam National
University
Gwangju, Republic of Korea
hdseby@jnu.ac.kr

Dong-Hyuk Shin

System Security Research Center, Chonnam National
University
Gwangju, Republic of Korea
shindh2@jnu.ac.kr

Ieck-Chae Euom

System Security Research Center, Chonnam National
University
Gwangju, Republic of Korea
iceuom@jnu.ac.kr

Abstract

As the adoption of electric vehicles (EVs) accelerates, ensuring the security of the EV charging infrastructure has become a critical challenge in the field of cyber-physical system (CPS) security. The EV charging system represents a complex CPS environment where physical and digital components are intricately coupled with intertwined layered communication protocols. These characteristics necessitate a comprehensive analysis of threat flows rather than merely identifying fragmented vulnerabilities. However, conventional threat modeling techniques often rely on static system analyses, providing threat checklists or security requirement specifications, limiting their ability to capture realistic attack paths and stepwise adversarial behaviors. More dynamic threat modeling approaches that incorporate attacker behavior flows are needed to address this limitation. This paper proposes a threat modeling method that analyzes system operation flows and asset interactions to identify critical attack points. This work constructs an attack tree based on this analysis and applies behavior-based threat classification at the leaf-node level. The resulting threat scenarios are linked to the MITRE adversarial tactics, techniques, and common knowledge framework with flows to generate actionable and executable attack scenarios. The proposed method is applied to a core component of the EV charging infrastructure (i.e., EV supply equipment) to derive scenarios, including remote intrusions, physical access attacks, and supply chain compromises. The scenarios are designed to be directly executable in breach and attack simulation environments, enabling automated and repeatable validation of security controls and facilitating proactive defense planning.

*Corresponding author

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than the author(s) must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

CSCS '25, Taipei, Taiwan

© 2025 Copyright held by the owner/author(s). Publication rights licensed to ACM.
ACM ISBN 979-8-4007-1928-8/2025/10
<https://doi.org/10.1145/3736130.3762689>

CCS Concepts

• Security and privacy; • Embedded systems security; • Computer systems organization; • Embedded and cyber-physical systems; • Software and its engineering; • Software testing and debugging;

Keywords

Electric vehicle charging infrastructure (EVCI), Threat modeling, Attack scenario

ACM Reference Format:

Jae-Jun Ha, Dong-Hyuk Shin, Chae-Min Lim, and Ieck-Chae Euom. 2025. Structured Threat Modeling Approach for Generating Executable Attack Scenarios in the EV Charging Infrastructure. In *Proceedings of the 2025 Cyber Security in CarS Workshop (CSCS '25)*, October 13–17, 2025, Taipei, Taiwan. ACM, New York, NY, USA, 10 pages. <https://doi.org/10.1145/3736130.3762689>

1 Introduction

The widespread adoption of electric vehicles (EVs) has elevated the security of the charging infrastructure to a critical concern in cyber-physical systems (CPSs). This infrastructure comprises a heterogeneous network of components, including EV supply equipment (EVSE), mobile applications, charging station management systems (CSMSs), and roaming platforms, which communicate via various protocols, such as the Open Charge Point Protocol (OCPP) [1] and ISO 15118 [2]. Among these, the EVSE serves as a physical and logical boundary between external users and internal systems, making it a primary attack target. As critical functions, such as authentication, billing, and remote firmware updates, become increasingly automated, a single cyber vulnerability can trigger cascading physical failures or widespread service disruptions. Real-world incidents, such as brokenwire-style [3] denial-of-service (DoS) attacks and remote code execution vulnerabilities in publicly exposed CSMS portals, underscore the immediacy and severity of these risks.

However, traditional threat modeling approaches in CPS environments are often limited to static system design assessments or the identification of isolated threats. These methods typically fail to capture attacker behavior patterns, including privilege escalation and lateral movement, resulting in fragmented threat lists without sufficient context to support prioritization and response.

This work proposes a structure-to-behavior threat modeling method that combines a system interaction analysis with adversary-centric scenario generation to address these limitations. The proposed method identifies critical processes and asset relationships based on system operational flows. Then, this approach constructs attacker-centric attack trees, performs behavior-based threat classification at the leaf-node level, and maps the threats to the corresponding tactics, techniques, and procedures (TTPs) from the MITRE adversarial tactics, techniques, and common knowledge (ATT&CK) [4] framework. These TTPs are prioritized using the observed–exploitability scoring model and are logically sequenced to reflect the attacker’s life cycle. The resulting multistage threat scenarios offer a more realistic and actionable basis for simulation-driven security validation and defense planning.

This paper presents the following primary contributions:

- We propose a threat modeling method that shifts from static component-level assessment to behavior-driven attack scenario generation based on the attacker’s intent and flow logic.
- We demonstrate the application of the proposed method to EVSE (the primary attack target in the EV charging infrastructure) and derive realistic multistage scenarios covering remote intrusion, supply chain compromise, and physical tampering.
- We construct executable attack scenarios by chaining MITRE ATT&CK TTPs designed for deployment in breach and attack simulation (BAS) environments to support repeatable security validation and mitigation planning.
- This work suggests that the proposed approach has the potential to enhance the structural visibility of the system and may support the development of proactive and testable defense strategies, aligning with recent cybersecurity guidance for the EV charging infrastructure (e.g., NIST IR 8473 [5]).

The remainder of this paper is organized as follows. Section 2 reviews the background and related work on CPS threat modeling and EV charging security. Next, Section 3 presents the proposed method in detail, including the system decomposition, attack tree construction, and scenario generation. Then, Section 4 applies the method to a real-world EVSE environment, illustrating the generation and validation of attack scenarios. Finally, Section 5 concludes with a discussion of the critical findings, limitations, and future work directions.

2 Background and Related Work

2.1 Electric Vehicle Charging Infrastructure Architecture and Security Challenges

The EV charging infrastructure is a complex CPS comprising several components: EVs, EVSE, CSMS, roaming platforms, and user-facing mobile applications. These components interact in real time via multiple communication protocols, including OCPP, ISO 15118, and IEC 61850 [6], to automate processes ranging from session initiation and user authentication to billing and firmware updates.

Figure 1 illustrates the layered architecture of the EV charging infrastructure (EVCI), divided into the cyber and physical domains.

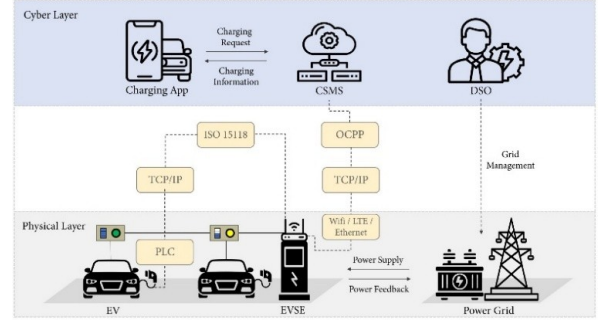


Figure 1: Electric Vehicle Charging Infrastructure Architecture as a Cyber-physical System

For example, communication between EVs and the EVSE is established via ISO 15118 over power line communication, whereas the EVSE connects with the backend CSMS over OCPP. The CSMS may also coordinate with distribution system operators for grid management. Most data exchanges rely on the Transmission Control Protocol/Internet Protocol, positioning the EVSE as the core interface that bridges the physical energy flow and cyber control commands.

Although this architecture enables operational efficiency and scalability, it also exposes the system to a complex and interconnected threat landscape. As the central communication and control hub, the EVSE is responsible for critical operations, such as power delivery, remote firmware updates, and authentication. These functions make this architecture one of the most sensitive attack targets in EVCI.

Recent studies underscore the urgency of securing EVSE. For instance, Szakály et al. [7] analyzed 325 Combined Charging System DC chargers across four European countries and found that only 12% employed transport layer security (TLS) encryption; the remaining 88% relied on unencrypted protocols, leaving them vulnerable to eavesdropping, session hijacking, and command manipulation. Additionally, EVSEs are often installed in public or semi-public spaces, making them vulnerable to physical intrusions via USB ports, debug interfaces, or direct tampering.

This combination of digital and physical vulnerabilities reflects the quintessential challenges of CPS security. Accordingly, this study focuses on EVSE as the target of a structured threat modeling approach. By integrating the system structure analysis with behavior-driven scenario generation, this work aims to uncover realistic and actionable attack vectors in EVSE environments.

2.2 Threat Modeling Approaches and Limitations in Cyber-Physical Systems

In the CPS environment, cyber attacks can have direct physical consequences. Effective threat modeling analyzes asset relationships, data flows, and trust boundaries to derive contextual and actionable threat scenarios while supporting threat prioritization and defense planning. Various threat modeling methods have been adapted for CPS, yet they differ considerably in abstraction level, interaction modeling, and representation of adversarial behavior.

One traditional method categorizes threats into spoofing, tampering, repudiation, information disclosure, DoS, and elevation of privilege (STRIDE [8]) based on the system data flow diagram (DFD). Although STRIDE offers a structured approach for threat identification, it fails to capture adversarial behavior flows, lateral movements, and multistage attack scenarios in dynamic CPS environments. Tuma et al. [9] noted that STRIDE tends to generate numerous low-impact threats, inducing decision fatigue and hindering effective prioritization.

To overcome such limitations, scenario-based methods like the Process for Attack Simulation and Threat Analysis (PASTA [10]) have been introduced. PASTA uses a seven-stage process to integrate adversarial behavior with business impact analysis. These stages include defining business objectives, decomposing the system, identifying threats, and simulating attack scenarios. However, in CPS contexts, PASTA has several key limitations: it insufficiently reflects physical-layer control flows and real-time interactions, and its procedural complexity makes it difficult to adopt in environments that require responsiveness and lightweight execution. Lee et al. [11] pointed out that PASTA needs to be complemented with physical constraints and CPS-specific threats or protocols in order to be effectively applied in such domains.

Other techniques, including Attack Trees [12] and the Cyber Kill Chain [13], have seen partial application in CPS. However, Attack Trees tend to represent static attack paths rather than dynamic sequences, while the Cyber Kill Chain's high-level phases are too abstract to capture the detailed tactics unique to CPS environments. Consequently, both techniques struggle to fully represent multi-stage attacker behavior, real-time system reactions, and the complexity of asset interactions.

These limitations persist even in specialized domains like the connected and autonomous vehicle (CAV) sector, which has seen the development of frameworks such as HEAVENS [14], TARA [15]. These models primarily target in-vehicle systems, electronic control units (ECUs), and V2X communication paths to address safety and security risks. However, they typically abstract out infrastructure-side components such as electric vehicle supply equipment, despite the fact that EVSEs play a critical role during the charging phase. This gap is increasingly relevant given that EVSEs communicate with vehicles via protocols like ISO 15118, forming new trust boundaries that are often overlooked in existing CAV-focused models.

In summary, existing threat modeling approaches, both general and domain-specific, often fall short in addressing the unique requirements of CPS, particularly in terms of adversary-behavior modeling and executable threat scenario development. As a result, recent research has increasingly turned toward behavior-based threat modeling and attacker TTP frameworks. This study seeks to fill the aforementioned gap by providing a structured, behavior-based threat modeling approach specifically designed for the EVSE environment.

2.3 Behavior-Based Threat Analysis and MITRE ATT&CK Framework

Conventional threat modeling techniques typically emphasize a static analysis of the system structure and data flows, making it challenging to capture the attacker's intent, infiltration paths, and

the temporal progression of threat behaviors. In CPS environments, where cyber operations directly affect physical outcomes, how attacks unfold over time must be modeled in the operational context.

The MITRE ATT&CK framework was introduced to address these limitations. This framework provides an empirically grounded taxonomy of adversarial behavior organized into TTPs. It has become the de facto standard for behavior-driven threat analysis, threat hunting, intrusion detection, and red teaming. In 2020, the framework was extended to industrial control systems, covering industrial control and CPS environments and incorporating threats such as firmware tampering, programmable logic controller (PLC) logic manipulation, and physical interface abuse.

MITRE Engenuity [16] proposed a practitioner guide for translating traditional modeling outputs—such as those derived from STRIDE or attack trees—into ATT&CK-based threat scenarios. This approach emphasizes the value of integrating structural modeling with behavioral frameworks to enhance realism, repeatability, and automation in validating the security of cyber-physical and industrial systems.

Academic studies have also explored similar integrations. For instance, Nicoletti et al. [17] mapped leaf nodes of attack trees to ATT&CK TTPs to construct complex, time-aware attack campaign scenarios using logical operators. Moreover, CMS Security [18] offers practical guidance for mapping STRIDE-identified threats to MITRE ATT&CK TTPs, helping organizations prioritize and address key security gaps.

Recent research has increasingly focused on integrating structural threat modeling methods such as STRIDE and attack trees with behavioral frameworks like MITRE ATT&CK. These efforts aim to enable the generation of realistic, multistage attack scenarios and improve the practical relevance of threat analysis in complex CPS environments. The method proposed in this study follows this emerging direction.

2.4 Behavior-Driven Threat Modeling for EVSE

The EVCI represents a typical example of a CPS, where cyber attacks can directly affect physical safety and the operation of the power infrastructure. Hence, precise and executable threat modeling methods tailored to EVCI environments are increasingly necessary. Although some recent studies have applied static analysis techniques, including STRIDE and attack trees, to EVCI, these efforts remain limited in scope.

For example, Subran et al. [19] applied STRIDE to classify threats in EVSE components and simulated a network-based DoS scenario. In contrast, Sagdullaev et al. [20] investigated the effect of cyberattacks on fleet charging systems on grid stability. However, these studies focus on structural threat enumeration and do not sufficiently capture attacker behavior flows, TTP-based scenario construction, or simulation feasibility.

This study aims to overcome these limitations by proposing a scenario-based threat modeling method focused on EVSE. The proposed approach applies STRIDE to the leaf nodes of attacker-centric attack trees rather than traditional DFD elements, enabling context-aware threat identification in realistic attack paths. This approach mitigates the problem of threat explosion and facilitates the prioritization of meaningful threats. Each leaf node is mapped and

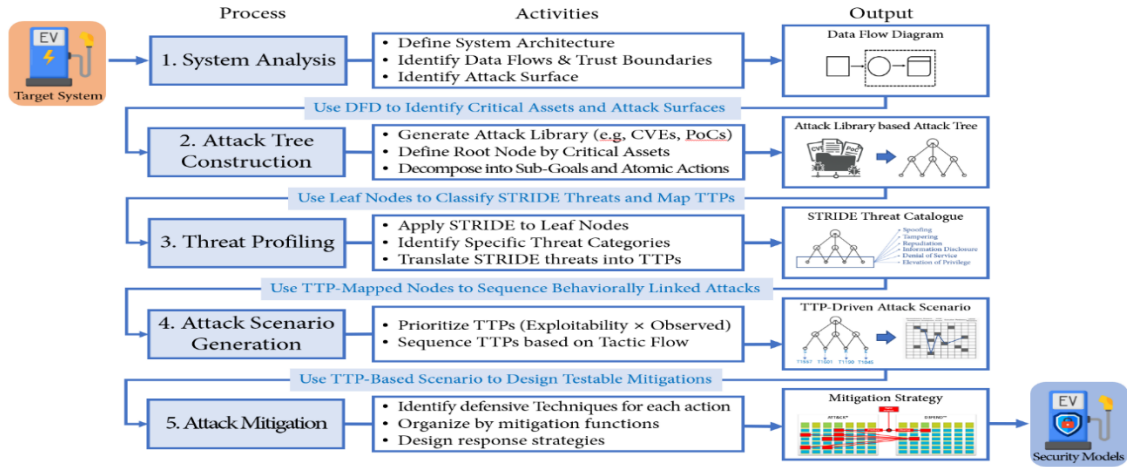


Figure 2: Five-stage threat modeling method integrating system analysis, attack scenario generation, and mitigation planning

sequenced to relevant TTPs from the MITRE ATT&CK framework, forming multistage attack scenarios reflecting the tactical progression of adversarial behavior. This integration enables generating executable threat scenarios suitable for simulation environments, supporting practical security validation and defense planning.

Essentially, the proposed method provides an integrated pipeline that transforms high-level system architecture into low-level, prioritized, and executable adversarial behaviors. By combining static structural analysis with dynamic behavior modeling, this unified approach addresses the limitations of traditional techniques and contributes to the generation of realistic and repeatable threat scenarios, offering a practical pathway to proactive cybersecurity assurance for CPS environments like EVCI.

3 Method

3.1 Proposed Approach

This study proposes a five-stage threat modeling method that integrates structural and behavioral analyses to address the complexity and real-time nature of CPS and the domain-specific characteristics of EVCI. Centered on EVSE, the approach is designed to derive realistic, multistage attack scenarios and inform actionable defense strategies.

Figure 2 presents the method consisting of the following sequential stages:

- 1. System Analysis:** The EVCI architecture is decomposed into individual components to identify critical assets, data flows, and trust boundaries. A DFD is constructed to capture the interactions between the cyber and physical layers and to define the attack surface of the system.
- 2. Attack Tree Construction:** Based on public vulnerability databases, technical documentation, and proof-of-concept materials, attack trees are constructed to model the possible paths adversaries could take to achieve their goals. These trees serve as a structural foundation for subsequent threat profiling and scenario generation.

3. Threat Profiling: The STRIDE classification scheme is applied to the leaf nodes of the attack tree to identify threats along each attack path systematically. This approach prevents the overgeneration of threat items and enables context-aware classification, facilitating executable scenario development.

4. Attack Scenario Generation: Each identified threat is mapped to the corresponding TTPs from the MITRE ATT&CK framework. These TTPs are sequenced based on tactical progression and technical feasibility using the observed–exploitability scoring model. The result is a set of coherent, executable attack scenarios.

5. Attack Mitigation: For each derived scenario, corresponding defensive measures are identified using the MITRE D3FEND framework [21]. Mitigation strategies are prioritized based on threat severity and implementation feasibility.

By integrating structural threat identification with behavior-based modeling, the proposed method supports the generation of repeatable and realistic threat scenarios, enabling proactive security validation and defense planning in complex CPS environments, such as EVCI.

3.2 System Analysis

System analysis serves as the foundational stage of the proposed threat modeling method. Its primary objective is to decompose the target system’s structure and operational flows to identify key assets, data exchanges, and potential attack surfaces. This step ensures that subsequent modeling activities are grounded in an accurate understanding of the architecture.

In CPSs, where physical and digital components are tightly integrated, a system analysis must account for a wide range of elements, such as sensors, controllers, communication modules, and external services. A DFD is constructed to represent the data flow visually and control signals between internal processes, external entities, and data repositories, formalizing this process.

During DFD creation, the method identifies major system processes, data stores, and external actors and maps the flow of information between them. Special attention is focused on defining the trust boundary, demarcating the interface between trusted internal components and potentially untrusted external inputs. This approach enables the identification of interaction points that could be exploited by adversaries and informs threat and attack-path modeling.

The outcome of this stage serves as the architectural basis for the following steps, including attack-tree construction, STRIDE-based threat classification, and behavior-driven scenario generation. This stage contributes to maintaining consistency and feasibility across the entire threat modeling workflow.

3.3 Attack Tree Construction

In the second stage, an attack tree is constructed to formalize how an adversary could achieve specific objectives by exploiting vulnerabilities in the target CPS environment. The process begins with the creation of an attack library comprising known vulnerabilities, including common vulnerabilities and exposures (CVEs), publicly available proof-of-concept exploits, technical security reports, and protocol-specific threat documentation. These sources provide a grounded reference set of plausible adversarial actions, helping to ensure realism in scenario modeling.

The tree construction proceeds through four conceptual phases. First, domain-specific technical artifacts—such as firmware vulnerabilities, misconfiguration patterns, exposed interfaces, and publicly available exploit scripts—are collected to build a comprehensive attack library. Second, a high-level adversarial objective is defined as the root node, representing a critical system compromise goal, such as disrupting system operations or gaining unauthorized control over backend services. Third, this objective is decomposed into intermediate sub-goals and then into atomic-level actions, each representing the smallest executable unit of attack, such as exploiting a debug interface, injecting malformed protocol messages, or spoofing authentication handshakes.

Finally, the resulting nodes are organized using the AND and OR logical relationships to express the dependencies, conditions, and alternative execution paths. The AND nodes indicate steps that must be jointly satisfied, whereas OR nodes offer alternate options for achieving a sub-goal. This hierarchical structure models realistic exploit chains, reflecting the complexity and flexibility of adversarial strategies.

This tree serves as the analytical foundation for subsequent threat profiling, in which each leaf node is categorized using STRIDE and mapped to relevant MITRE ATT&CK techniques.

3.4 Threat Profiling

The third stage of the method, threat profiling, transforms system-level vulnerabilities into actionable threat intelligence by applying STRIDE classification and behavior-based mapping to the leaf nodes of the attack tree. Each node represents an atomic adversarial action and is categorized based on the security property it violates, using the STRIDE framework. For example, forging an authentication token corresponds to spoofing, whereas modifying an OCPP payload represents tampering.

The STRIDE classification permits a structured assessment of the effect of each threat on the core security attributes. In parallel, these threats are mapped to relevant TTPs from the MITRE ATT&CK framework to reflect their behavioral dimensions. Mapping considers the technical context, attacker intent, and observed exploitation methods relevant to the target CPS environment. Relevant data sources include CVE databases, threat intelligence feeds, and ATT&CK use cases tailored to industrial control systems.

The profiling process reveals how structurally defined threats can be practically executed in real-world adversarial scenarios by performing this dual-layered analysis at the leaf-node level. Unlike traditional DFD-based STRIDE assessments, this node-centric approach establishes a more precise and granular correspondence between architectural vulnerabilities and attacker operations.

This stage provides a unified threat catalog. Each entry in the catalog typically includes Node ID, STRIDE type, ATT&CK TTP ID, attack prerequisites, and affected system components. This comprehensive catalog serves as the foundation for the next stage, where executable attack scenarios are synthesized via TTP sequencing based on tactical progression and feasibility.

3.5 Attack Scenario Generation

In the fourth stage, the method transitions from structural threat identification to behavior-based scenario generation by applying the TTP mappings established in the previous phase. This step connects architectural vulnerability analysis with adversarial behavior modeling to generate executable threat scenarios tailored for CPS environments.

Each threat, classified using STRIDE and mapped to corresponding TTPs from the MITRE ATT&CK framework, is incorporated into logically ordered adversarial flows. Rather than listing TTPs in isolation, the method sequences them according to tactical progression based on system context, functional roles, and technical feasibility.

Prioritization is guided by two factors: Observed and Exploitability. Each TTP is assigned a score calculated as:

$$\text{Priority (TTP}_i\text{)} = \text{Exploitability (TTP}_i\text{)} \times \text{Observed (TTP}_i\text{)}.$$

Exploitability reflects the technical feasibility of executing the TTP, considering the availability of public exploits, required privileges, and system compatibility. Higher values represent techniques that are broadly applicable and easy to deploy, whereas lower values correspond to those that require physical access or remain largely theoretical. *Observed* captures how frequently the TTP has appeared in threat intelligence feeds or real-world incident reports, with higher scores assigned to widely documented techniques.

Scenario construction proceeds in two phases. First, TTPs are grouped according to the adversary lifecycle stages defined in the ATT&CK matrix (e.g., Initial Access, Execution, Lateral Movement, Impact). Then, logical dependencies are resolved to ensure that prerequisite steps are completed before dependent actions are executed. Within each stage, the highest-priority TTPs are selected to form technically feasible and coherent attack sequences.

The resulting scenarios are encoded in structured formats such as YAML, allowing seamless integration with BAS platforms and digital twin environments. This encoding facilitates repeatable security validation and dynamic adversary emulation. Frameworks

like Atomic Red Team [22] exemplify this approach, as they define ATT&CK TTPs as YAML-based executable modules, enabling real-world simulation of attack scenarios across test environments.

Algorithm 1 Tactic, Technique, and Procedure (TTP)-based Attack Scenario Generation

Input: STRIDE-classified attack tree leaf nodes; TTPs with exploitability and observed scores

Output: Executable, prioritized attack scenarios

1. For each leaf node:
 - a. Identify relevant TTPs (via STRIDE and system context)
 - b. For each TTP:

$$\text{compute Priority} = \text{Exploitability} \times \text{Observed}$$
 - c. Group TTPs by tactic
 - d. Select the highest-priority TTP from each tactic
 2. For each selected starting TTP:
 - a. Initialize the scenario with the starting TTP
 - b. While the current tactic is not Impact:
 - Identify next TTPs with valid progression from the last TTP in the scenario
 - Select the highest-priority feasible TTP
 - If none found, break
 - Else, add the selected TTP to the scenario
 - c. Add the completed scenario to the scenario list
 3. Return the constructed scenarios
-

3.6 Attack Mitigation

The final stage focuses on translating attack scenarios into actionable defense strategies by applying the MITRE D3FEND framework. The MITRE ATT&CK framework describes adversary behaviors, and the D3FEND framework complements it by providing a structured taxonomy of defensive techniques designed to counter specific TTPs. This alignment allows security analysts to develop targeted, threat-informed mitigations directly addressing the techniques identified in each scenario.

For every derived attack scenario, the associated TTPs are mapped to the corresponding D3FEND countermeasures, categorized into five critical defensive functions: hardening, detection, isolation, deception, and response. Hardening involves secure configurations, such as firmware integrity validation and enforcing encrypted communication. Detection focuses on identifying anomalies by inspecting network traffic and endpoint telemetry. Isolation restricts adversary movement via access control and network segmentation. Deception introduces misleading artifacts, such as honeypots or emulated systems, to confuse or delay attackers. Finally, the response includes automated actions for incident correlation, containment, and recovery.

This method provides a solid foundation for threat-informed defense planning by systematically aligning attacker behaviors with defensive capabilities. The proposed method helps identify suitable mitigations for specific threats and reveals coverage gaps in the existing security posture. Furthermore, these defense mappings can be incorporated into security orchestration, automation, and response platforms (SOAR [23]) or other operational defense systems, permitting scalable and automated implementation of threat-informed countermeasures.

4 Case Study for Electric Vehicle Supply Equipment

This work presents a case study focused on EVSE, a central node in the EV charging infrastructure, to validate the applicability and effectiveness of the proposed structured threat modeling approach. The EVSE is selected as the primary analysis target because it serves as a critical asset at the intersection of physical charging hardware and backend management systems. This dual role exposes the equipment to a broad range of attack surfaces, ranging from protocol-level exploits such as ISO 15118 handshake manipulation to firmware compromise.

This case study applies all five stages of the proposed method to the EVSE environment. The analysis scope is restricted to the internal modules of the EVSE and its communication with external entities, namely electric vehicles (via ISO 15118) and charging station management systems (via OCPP), while excluding broader ecosystem interactions such as utility grid operations. The following sections describe the application of each modeling phase—from system analysis to threat classification and scenario development—grounded in the real-world architecture and plausible adversarial behavior.

4.1 System Analysis

This section analyzes the architecture of the EVSE to define system boundaries, identify core internal components, and delineate potential attack surfaces. The EVSE serves as an intermediary between the EV and CSMS, managing power delivery and communication functions. The EVSE has a dual role at the cyber-physical interface, making it a critical node for threat modeling.

As illustrated in Figure 3, the EVSE is organized around a central control module (P1: Manage EVSE Functions), which orchestrates internal operations and exchanges data with external systems. This module interacts with six subsystems, each modeled as a process in the system DFD:

- Handle External Communication (P2): This module represents the supply equipment communication controller, which manages external communications. This module relays 1) ISO 15118 messages to and from the EV and 2) OCPP messages to and from the CSMS, functioning as the protocol translation and transport layer between the physical vehicle interface and backend management system.
- Display Status and Receive Input (P3): This module corresponds to the human-machine interface, enabling basic user interaction such as starting or stopping charging, and provides real-time visual feedback on the charging status. This module also serves as a potential physical access point for adversaries.
- Control Power Flow to EV (P4): This power relay module regulates the delivery of the charging current and voltage to the vehicle. This module receives control signals from the central controller (P1) and executes them at the hardware level, making it a critical point for physical-layer manipulation.
- Manage Cooling System (P5): This module controls the internal thermal regulation subsystem, ensuring the charger operates within safe temperature thresholds during high-load

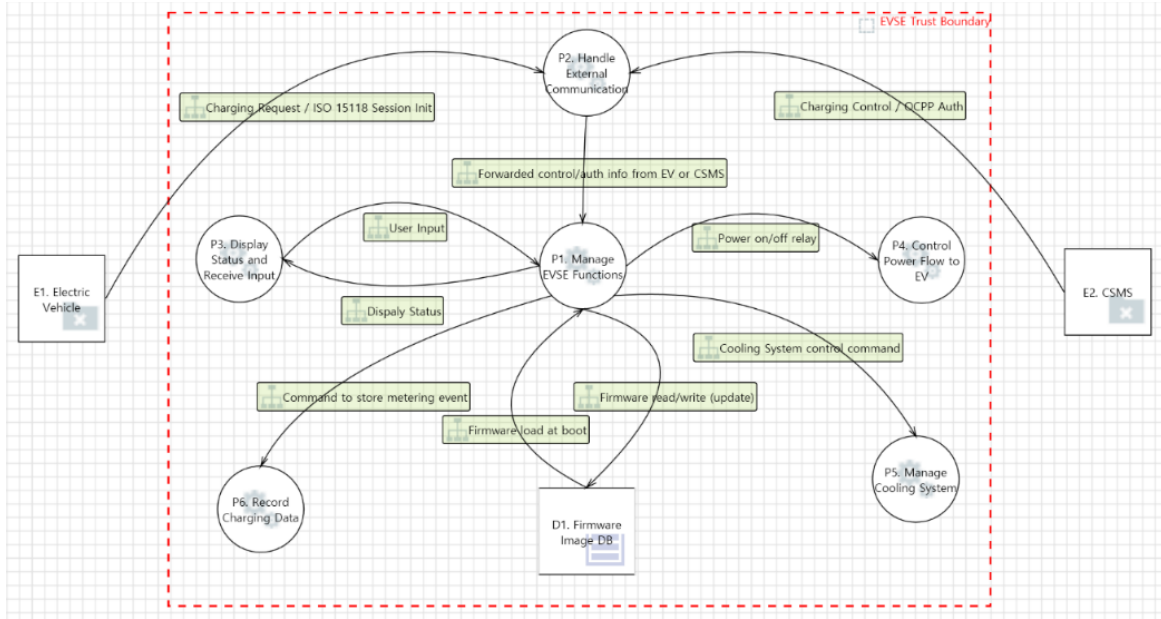


Figure 3: Data Flow Diagram (DFD) of electric vehicle supply equipment (EVSE)

conditions. This system monitors heat sensors and activates cooling mechanisms, such as fans or liquid systems.

- Record Charging Data (P6): This module represents the metering subsystem, which logs charging session details, including energy consumption, timestamps, and session identifiers. These data are used for billing, compliance, and (in some cases) regulatory auditing.
- Firmware Image Database (D1): This module manages the firmware storage and update repository, storing executable system firmware and serving as the source for boot-time and remote updates. This module is critical for secure system integrity and is often a target for supply chain or persistence attacks.

These modules are tightly integrated and interact with external actors (EV and CSMS) via structured data flows, some of which are potentially exposed to adversarial manipulation. Hence, the architecture proposes three distinct trust boundaries: (1) between the EV and EVSE, (2) between the CSMS and EVSE, and (3) within the EVSE—separating critical internal control logic from externally accessible interfaces, such as debug ports.

In turn, these boundaries reveal three major categories of attack surfaces: protocol interfaces such as ISO 15118 and OCPP; internal control logic including firmware and relay control mechanisms; and physical access vectors like diagnostic and maintenance ports.

4.2 Attack Tree Construction

Building on the architectural analysis from the previous stage, this phase constructs a hierarchical attack tree to model plausible adversarial goals and their corresponding exploitation paths.

The root node is defined as charger control, referring to any unauthorized manipulation of charging operations, power delivery, or internal data flows within the EVSE system. As shown in

Figure 4, the attack tree comprises three high-level categories: remote communication exploitation, physical access exploitation, and firmware/supply chain exploitation. These categories encompass protocol-based manipulation using ISO 15118 and OCPP, unauthorized physical access through interfaces such as USB, Universal Asynchronous Receiver-Transmitter (UART), and Joint Test Action Group (JTAG), and compromise of local firmware storage or update mechanisms.

Each node in the tree represents an adversarial objective or attack technique derived from a curated attack library. This library was developed through the review of 31 academic papers, 9 technical reports, 2 public incident disclosures, and a set of 16 documented CVEs affecting commercial EVSE products. To ensure transparency and traceability, the curation process followed a structured approach. Academic literature was used to extract insights into protocol-level vulnerabilities, architectural weaknesses, and emerging attack vectors. For instance, real-world studies such as Brokenwire and ChargePrint [24] were referenced to understand practical side-channel attacks and web interface exploitations on EVSE systems. Technical reports provided vendor-specific threat insights and analysis of firmware vulnerabilities and misconfigurations. Public incident disclosures helped identify adversarial behaviors observed in the field. Additionally, CVE records were used to understand recurring vulnerability trends across EVSE product lines, informing the practical feasibility of certain attack paths.

The extracted techniques were then normalized and organized into a structured attack tree based on logical dependencies and high-level attack objectives. The relationships between nodes were expressed using AND and OR logic to capture both required conditions and alternative execution strategies. This structured representation enables realistic modeling of adversarial behavior and

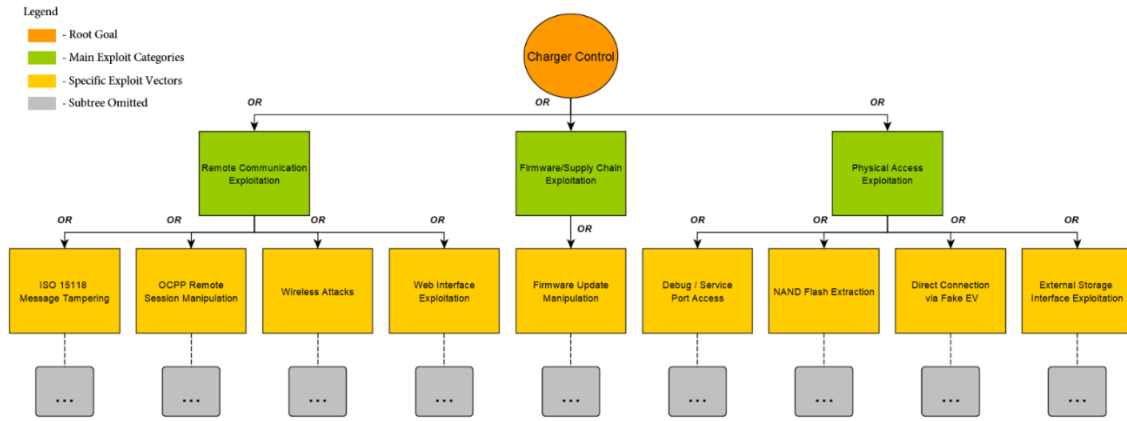


Figure 4: High-level attack tree for electric vehicle supply equipment (EVSE) charger control, illustrating major exploit categories and specific attack vectors across remote, firmware, and physical access domains

serves as the foundation for STRIDE-based threat classification and subsequent TTP-based scenario generation.

4.3 Threat Profiling

At this stage, the EVSE-specific leaf nodes of the attack tree are profiled using a dual-layered approach integrating structural classification and behavior-based characterization. Each leaf node represents a single adversarial action and is assessed using the STRIDE framework to identify the security property that is violated. For example, “forging authentication tokens” corresponds to spoofing, whereas “modifying OCPP payloads” is classified as tampering, establishing a precise relationship between architectural vulnerabilities and threat attributes.

Each threat is linked to the corresponding tactics and techniques from the MITRE ATT&CK framework to describe how it may be realized from a behavioral standpoint. This linkage is structured based on the security properties and technical characteristics of the identified threats. Therefore, most threats identified for the EVSE are concentrated in the initial access and execution tactic categories. This finding reflects the fact that EVSE exposes a wide range of external interfaces, including web user interfaces, debug ports, ISO 15118, and OCPP protocols, which serve as critical entry points for attacks.

This analysis enhances the attacker-centric perspective while structuring threats to ensure consistency for scenario generation in the following phases. Notably, performing a STRIDE analysis at the leaf-node level rather than at the component level significantly improves the traceability and alignment between structural vulnerabilities and executable threats.

Table 1 summarizes nine representative threats from the 30 leaf nodes analyzed at this stage, detailing their STRIDE classifications, associated ATT&CK TTPs, and corresponding tactic categories. This mapping connects structural and behavioral threat aspects to support scenario generation.

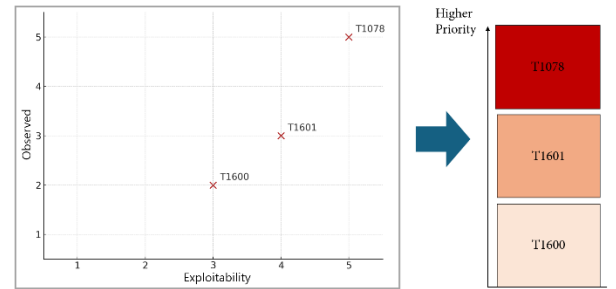


Figure 5: Prioritization matrix of tactics, techniques, and procedures (TTPs) using observed and exploitability scores.

4.4 Scenario Generation

In this phase, executable attack scenarios for the EVSE environment are generated based on the attack tree and the STRIDE-ATT&CK threat profiling results. Each candidate threat is evaluated using an observed-exploitability score, with values assigned on a 5-point scale. These scores guide the selection of impactful and realistic TTPs for scenario generation.

To ensure comparability, TTPs sharing the same ATT&CK tactic are grouped and then ranked based on their (Observed, Exploitability) scores. Figure 5 visualizes this ranking process for the *Defense Evasion* tactic. Among T1600 (Weaken Encryption), T1601 (Modify System Image), and T1078 (Valid Accounts), the last is selected as the highest-priority threat due to its strong support from both real-world disclosures (e.g., JTAG/UART-based compromises) and technical feasibility (default credentials, weak authentication mechanisms). Table 1 provides sample leaf nodes mapped to STRIDE, ATT&CK TTPs, and prioritization scores.

The detailed attack flow is as follows:

1. Active Scanning (T1595): The attacker performs network scanning to identify exposed EVSE devices with accessible web interfaces.

Table 1: Attack tree leaf nodes mapped to STRIDE categories and MITRE ATT&CK tactics, techniques, and procedures (TTPs) for scenario construction

Leaf-node	STRIDE	MITRE ATT&CK TTP	Tactic	Observed ^a	Exploitability ^b
Lack of TLS	T, I	T1600 – Weaken encryption	Defense evasion	2	3
Firmware update manipulation	E	T1601 - Modify system image	Defense evasion	3	4
Bypassing authentication	E	T1078 - Valid accounts	Initial access, defense evasion	5	5
Malicious firmware upload	T, E	T1495 - Firmware corruption	Impact	3	1
Brokenwire attack	D	T1499 - Denial of Service	Impact	3	4
NAND flash dump	I	T1005 - Data from the local system	Collection	4	2
Update server attack	T, S	T1195.002 - Compromise software supply chain	Initial access	4	4
MITM update command injection	T	T1557 - Adversary-in-the-middle	Credential access, collection	3	3
Local firmware storage exploitation	T, R	T1496 - Resource hijacking	Impact	3	2

^a Observed score scale: 1 (rare) – 5 (frequent), ^b Exploitability score scale: 1 (low) – 5 (high).

2. Exploit Public-Facing Application (T1190): A vulnerability in the web application is exploited to bypass authentication or inject malicious payloads.
3. Valid Accounts (T1078): Default credentials are used to maintain persistent access to the EVSE control interface.
4. Command and Scripting Interpreter (T1059): The attacker executes arbitrary commands to tamper with firmware-related components.
5. Firmware Corruption (T1495): By modifying or corrupting firmware images, the attacker impairs charging functionality and causes service degradation.

By chaining these TTPs, the scenario spans from the initial EVSE compromise to sustained control and ultimate service disruption.

4.5 Attack Mitigation

This phase maps each step of the previously constructed attack scenario to the corresponding defensive techniques from the MITRE D3FEND framework. This mapping process helps translate adversarial behavior into actionable countermeasures for the EVSE environment.

The D3FEND techniques are selected based on the functional characteristics of the associated ATT&CK TTPs. For instance, techniques related to credential compromises such as T1110 are linked to credential hardening (D3-CH) and the decoy user credential (D3-DUC), whereas command execution (T1059) maps to execution isolation (D3-EI) and executable allowlisting (D3-EAL). Discovery-related behavior (T1046) is addressed using network traffic filtering (D3-NTF) and network isolation (D3-NI).

In EVSE systems where remote control and user authentication are fully automated, even a limited compromise can disrupt charging services. Thus, single-point patching is insufficient. Operators can substantially enhance the resilience of EVSE deployments and proactively address CPS-specific threats by adopting layered defenses, such as isolation, deception, and allowlisting.

5 Conclusion

This paper proposes a structured and behavior-driven threat modeling methodology tailored to the characteristics of EVCI. The method integrates data-flow-based system analysis, STRIDE threat classification, hierarchical attack tree construction, and behavior-oriented profiling using the MITRE ATT&CK framework. It supports not only threat identification but also generation of multistage attack scenarios. Furthermore, the method links each threat stage to corresponding mitigation strategies through MITRE D3FEND, enabling an end-to-end integrated security planning approach.

A key contribution of this method is its ability to generate domain-specific, executable attack scenarios that support a repeatable security validation loop—from threat modeling, through mitigation, to verification. This proactive, closed-loop posture enables security teams to simulate realistic adversary behavior and systematically evaluate corresponding defenses, particularly for high-risk and dynamic CPS environments. Importantly, the repeatable loop structure also provides adaptability to emerging threats, as newly identified TTPs can be incorporated into the model and re-validated within the same framework.

To validate the method, a case study was conducted on EVSE, a core component of EVCI. The study identified EVSE-specific adversarial paths, including physical access-based control, protocol manipulation over ISO 15118 and OCPP, and supply chain compromise via update servers. Each threat was assessed based on Observed and Exploitability scores, which were then used to prioritize and construct realistic multistage attack scenarios. These scenarios can be applied to BAS and security strategy validation in practical settings.

However, this study is limited to a conceptual case study on a single EVSE instance, without real-world BAS integration or hardware-level threat analysis. Further work is required to enhance the generalizability and operational applicability of the approach.

Future research will focus on integrating the framework with digital twin-enabled BAS platforms to enable dynamic threat simulation and automated defense validation. Additionally, the methodology will be extended to broader CPS domains such as smart grids, smart factories, and autonomous systems to assess its scalability and adaptability.

Acknowledgments

This research was supported by the Korea Internet & Security Agency (KISA) through the Information Security Specialized University Support Project (50%), and by the Nuclear Safety Research Program through the Korea Foundation of Nuclear Safety (KoFONS) using the financial resource granted by the Nuclear Safety and Security Commission (NSSC) of the Republic of Korea (No. 2106061) (50%).

References

- [1] International Electrotechnical Commission. 2024. IEC 63584: Open Charge Point Protocol (OCPP). IEC, Geneva, Switzerland.
- [2] International Organization for Standardization. 2019. ISO 15118-2: Road vehicles – Vehicle to grid communication interface – Part 2: Network and application protocol requirements. ISO, Geneva, Switzerland.
- [3] Sebastian Köhler, Richard Baker, Martin Strohmeier, and Ivan Martinovic. 2023. BROKENWIRE: Wireless Disruption of CCS Electric Vehicle Charging. In Proceedings of the 2023 NDSS Symposium. ISOC/NDSS, San Diego, CA. <https://doi.org/10.14722/ndss.2023.23251>
- [4] MITRE. 2023. MITRE ATT&CK Framework. Retrieved June 19, 2025 from <https://attack.mitre.org/>
- [5] National Institute of Standards and Technology. 2022. NIST IR 8473: Cybersecurity Framework Profile for Electric Vehicle Extreme Fast Charging Infrastructure. U.S. Department of Commerce, Gaithersburg, MD. <https://doi.org/10.6028/NIST.IR.8473>
- [6] International Electrotechnical Commission. 2013. IEC 61850: Communication networks and systems for power utility automation. IEC, Geneva, Switzerland.
- [7] Dániel Szakály, Gábor Béres, Balázs Pejó, and Levente Buttyán. 2023. Cybersecurity evaluation of EV charge stations and protection measures. In Proceedings of the 2023 IEEE 19th International Conference on Factory Communication Systems (WFCS). IEEE, 1–7. <https://doi.org/10.1109/WFCS58077.2023.10156583>
- [8] Adam Shostack. 2014. Threat Modeling: Designing for Security (1st. ed.). Wiley Publishing.
- [9] Katja Tuma, Christian Sandberg, Urban Thorsson, Mathias Widman, Thomas Herpel, and Riccardo Scandariato. 2021. Finding security threats that matter: Two industrial case studies. *Journal of Systems and Software* 179 (2021), Article 111003. <https://doi.org/10.1016/j.jss.2021.111003>
- [10] Tony UcedaVelez and Marco M. Morana. 2015. Risk centric threat modeling: Process for attack simulation and threat analysis. *Journal of Cyber Security and Mobility* 3, 1 (2015), 65–103. <https://doi.org/10.13052/jcsm2245-1439.311>
- [11] Cher Chye Lee, Teik Guan Tan, Vishal Sharma, and Jianying Zhou. 2021. Quantum Computing Threat Modelling on a Generic CPS Setup. In Proceedings of the Third International Workshop on Artificial Intelligence and Industrial Internet-of-Things Security (AloTS '21). Lecture Notes in Computer Science, vol. 13218. Springer, Cham, 171–190. https://doi.org/10.1007/978-3-030-81645-2_11
- [12] Bruce Schneier. 1999. Attack Trees. *Dr. Dobbs's Journal of Software Tools* 24, 12 (Dec. 1999), 21–29.
- [13] Eric Hutchins, Michael Cloppert, and Rohan Amin. 2011. Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains. In Proceedings of the 6th Annual International Conference on Cyber Conflict (CyCon 2011). NATO CCDCOE, 1–12.
- [14] Törnigren, M., Raspotnig, C., & Jaatun, M. G. 2015. The HEAVENS Security Model: Threat Analysis for Vehicles. In Proceedings of the 2015 International Conference on Computer Safety, Reliability, and Security (SAFECOMP 2015), 131–146. Springer. https://doi.org/10.1007/978-3-319-24249-1_11
- [15] SAE J3061. 2016. Cybersecurity Guidebook for Cyber-Physical Vehicle Systems. SAE International. Warrendale, PA, USA.
- [16] The MITRE Corporation. 2024. Threat Modeling with ATT&CK v1.0.1. Center for Threat-Informed Defense. <https://center-for-threat-informed-defense.github.io/threat-modeling-with-attack/> (accessed June 19, 2025). Document number CT0122.
- [17] Stefano M. Nicoletti, Milan Lopuhaä-Zwakenberg, Mariëlle Stoelinga, Fabio Massacci, and Carlos E. Budde. 2023. How hard can it be? Quantifying MITRE attack campaigns with attack trees and cATM logic. In Proceedings of the 2023 ACM Asia Conference on Computer and Communications Security (AsiaCCS '23). Association for Computing Machinery, New York, NY, USA, 64–77. <https://doi.org/10.1145/3579856.3591631>
- [18] CMS Security. 2023. How to Use MITRE ATT&CK in Conjunction with Threat Modeling. Retrieved June 19, 2025 from <https://security.cms.gov/posts/how-use-mitre-attack-conjunction-threat-modeling>
- [19] Akshitha K. Subran. 2024. Threat Modeling and Attack Simulation of Charging Infrastructures in Electric Vehicles. In Proceedings of the International Conference on Trends in Advanced Computing and Engineering Applications (TACEA 2024). Springer, 87–95.
- [20] Farrukh Sagdullaev and Mohanpurkar Manish. 2024. Fleet Charging Infrastructure Resilience to Cybersecurity Threats. In Proceedings of the 2024 IEEE Power and Energy Society Innovative Smart Grid Technologies Conference (ISGT). IEEE, 1–5. <https://doi.org/10.1109/ISGT59792.2024.10457623>
- [21] The MITRE Corporation. 2021. D3FEND: A Knowledge Graph of Cybersecurity Countermeasures. Retrieved June 19, 2025 from <https://d3fend.mitre.org>
- [22] Red Canary. 2017. Atomic Red Team. Red Canary, Denver, CO, USA. Available at <https://github.com/redcanaryco/atomic-red-team>
- [23] Gartner. 2020. Market Guide for Security Orchestration, Automation and Response Solutions. Retrieved June 19, 2025 from <https://www.gartner.com/en/documents/3985385>
- [24] T. Nasr, S. S. Bhunia, M. Conti, and P. Gill. 2023. ChargePrint: A Framework for Internet-Scale Discovery and Security Analysis of EV Charging Management Systems. In Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security (CCS '23), ACM, New York, NY, USA, 18 pages. <https://doi.org/10.1145/3576915.3623182>